

Safeguard 17.6: Define Mechanisms for Communicating During Incident Response

Asset Type: Users	Security Function: Respond	IG2	IG3
-------------------	----------------------------	-----	-----

Determine which primary and secondary mechanisms will be used to communicate and report during a security incident. Mechanisms can include phone calls, emails, secure chat, or notification letters. Keep in mind that certain mechanisms, such as emails, can be affected during a security incident. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.7: Conduct Routine Incident Response Exercises

Asset Type: Users	Security Function: Recover	IG2	IG3
-------------------	----------------------------	-----	-----

Plan and conduct routine incident response exercises and scenarios for key personnel involved in the incident response process to prepare for responding to real-world incidents. Exercises need to test communication channels, decision making, and workflows. Conduct testing on an annual basis, at a minimum.

Safeguard 17.8: Conduct Post-Incident Reviews

Asset Type: Users	Security Function: Recover	IG2	IG3
-------------------	----------------------------	-----	-----

Conduct post-incident reviews. Post-incident reviews help prevent incident recurrence through identifying lessons learned and follow-up action.

Safeguard 17.9: Establish and Maintain Security Incident Thresholds

Asset Type: Documentation	Security Function: Recover	IG3
---------------------------	----------------------------	-----

Establish and maintain security incident thresholds, including, at a minimum, differentiating between an incident and an event. Examples can include: abnormal activity, security vulnerability, security weakness, data breach, privacy incident, etc. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

CONTROL 18

Penetration Testing

Safeguards: 5	IG1: 0/5	IG2: 3/5	IG3: 5/5
---------------	----------	----------	----------

Overview

Test the effectiveness and resiliency of enterprise assets through identifying and exploiting weaknesses in controls (people, processes, and technology), and simulating the objectives and actions of an attacker.

Why is this Control critical?

A successful defensive posture requires a comprehensive program of effective policies and governance, strong technical defenses, combined with appropriate action from people. However, it is rarely perfect. In a complex environment where technology is constantly evolving and new attacker tradecraft appears regularly, enterprises should periodically test their controls to identify gaps and to assess their resiliency. This test may be from external network, internal network, application, system, or device perspective. It may include social engineering of users, or physical access control bypasses.

Often, penetration tests are performed for specific purposes:

- As a “dramatic” demonstration of an attack, usually to convince decision-makers of their enterprise’s weaknesses
- As a means to test the correct operation of enterprise defenses (“verification”)
- To test that the enterprise has built the right defenses in the first place (“validation”)

Independent penetration testing can provide valuable and objective insights about the existence of vulnerabilities in enterprise assets and humans, and the efficacy of defenses and mitigating controls to protect against adverse impacts to the enterprise. They are part of a comprehensive, ongoing program of security management and improvement. They can also reveal process weaknesses, such as incomplete or inconsistent configuration management, or end-user training.

Penetration testing differs from vulnerability testing, described in CIS Control 7. Vulnerability testing just checks for presence of known, insecure enterprise assets, and stops there. Penetration testing goes further to exploit those weaknesses to see how far an attacker could get, and what business process or data might be impacted through exploitation of that vulnerability. This is an important detail, and often penetration testing and vulnerability testing are incorrectly used interchangeably. Vulnerability testing is exclusively automated scanning with sometimes manual validation of false positives, whereas penetration testing requires more human involvement and analysis, sometimes supported through the use of custom tools or scripts. However, vulnerability testing is often a starting point for a penetration test.

Another common term is “Red Team” exercises. These are similar to penetration tests in that vulnerabilities are exploited; however, the difference is the focus. Red Teams simulate specific attacker TTPs to evaluate how an enterprise’s environment would withstand an attack from a specific adversary, or category of adversaries.

Procedures and tools

Penetration testing starts with the reconnaissance of the enterprise and environment, and scanning to identify the vulnerabilities that can be used as entries into the enterprise. It is important to make sure all enterprise assets are discovered that are in-scope, and not just rely on a static list, which might be outdated or incomplete. Next, vulnerabilities will be identified in these targets. Exploits to these vulnerabilities are executed to demonstrate specifically how an adversary can either subvert the enterprise’s security goals (e.g., the protection of specific sensitive data) or achieve specific adversarial objectives (e.g., the establishment of a covert Command and Control (C2) infrastructure). The results provide deeper insight, through demonstration, into the business risks of various vulnerabilities. This can be against physical access controls, network, system, or application layers, and often includes social engineering components.

Penetration tests are expensive, complex, and potentially introduce their own risks. Experienced people from reputable vendors must conduct them. Some risks include unexpected shutdown of systems that might be unstable, exploits that might delete or corrupt data or configurations, and the output of a testing report that needs to be protected itself, because it gives step-by-step instructions on how to break into the enterprise to target critical assets or data.

Each enterprise should define a clear scope and rules of engagement for penetration testing. The scope of such projects should include, at a minimum, enterprise assets with the highest valued information and production processing functionality. Other lower-value systems may also be tested to see if they can be used as pivot points to compromise higher-value targets. The rules of engagement for penetration test analyses should describe, at a minimum, times of day for testing, duration of test(s), and the overall test approach. Only a few people in the enterprise should know when a penetration test is performed, and a primary point of contact in the enterprise should be designated if problems occur. Increasingly popular recently is having penetration tests conducted through third-party legal counsel to protect the penetration test report from disclosure.

The Safeguards in this CIS Control provide specific, high-priority steps that can improve enterprise security, and should be a part of any penetration testing. In addition, we recommend the use of some of the excellent comprehensive resources dedicated to this topic to support security test planning, management, and reporting:

OWASP Penetration Testing Methodologies: https://www.owasp.org/index.php/Penetration_testing_methodologies

PCI Security Standards Council: https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf

Safeguards

Safeguard 18.1: Establish and Maintain a Penetration Testing Program

Asset Type:	Documentation	Security Function:	Govern	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----

Establish and maintain a penetration testing program appropriate to the size, complexity, industry, and maturity of the enterprise. Penetration testing program characteristics include scope, such as network, web application, Application Programming Interface (API), hosted services, and physical premise controls; frequency; limitations, such as acceptable hours, and excluded attack types; point of contact information; remediation, such as how findings will be routed internally; and retrospective requirements.

Safeguard 18.2: Perform Periodic External Penetration Tests

Asset Type: Network	Security Function: Detect	IG2 IG3
---------------------	---------------------------	---------

Perform periodic external penetration tests based on program requirements, no less than annually. External penetration testing must include enterprise and environmental reconnaissance to detect exploitable information. Penetration testing requires specialized skills and experience and must be conducted through a qualified party. The testing may be clear box or opaque box.

Safeguard 18.3: Remediate Penetration Test Findings

Asset Type: Network	Security Function: Protect	IG2 IG3
---------------------	----------------------------	---------

Remediate penetration test findings based on the enterprise's documented vulnerability remediation process. This should include determining a timeline and level of effort based on the impact and prioritization of each identified finding.

Safeguard 18.4: Validate Security Measures

Asset Type: Network	Security Function: Protect	IG3
---------------------	----------------------------	-----

Validate security measures after each penetration test. If deemed necessary, modify rulesets and capabilities to detect the techniques used during testing.

Safeguard 18.5: Perform Periodic Internal Penetration Tests

Asset Type: Network	Security Function: Detect	IG3
---------------------	---------------------------	-----

Perform periodic internal penetration tests based on program requirements, no less than annually. The testing may be clear box or opaque box.

Appendix



Acronyms and Abbreviations

AAA	Authentication, Authorization, and Auditing
ACL	Access Control List
AD	Active Directory
AoC	Attestation of Compliance
API	Application Programming Interface
BEC	Business Email Compromise
C2	Command and Control
CCE	Common Configuration Enumeration
CDM	Community Defense Model
CIA	Confidentiality, Integrity, and Availability
CIS	Center for Internet Security
CIS-CAT	CIS Configuration Assessment Tool
COTS	Commercial off-the-Shelf
CPE	Common Platform Enumeration
CREST	Council of Registered Security Testers
CSA	Cloud Security Alliance
CSP	Cloud Service Provider
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
DBIR	Data Breach Investigations Report
DEP	Data Execution Prevention
DG	Development Group
DHCP	Dynamic Host Configuration Protocol
DKIM	DomainKeys Identified Mail
DLP	Data Loss Prevention
DMARC	Domain-based Message Authentication, Reporting, and Conformance
DMS	Database Management System

DNS	Domain Name System
DPI	Deep Packet Inspection
EDR	Endpoint Detection and Response
EOL	End of Life
FFIEC	Federal Financial Institutions Examination Council
FIRST	Forum of Incident Response and Security Teams, Inc.
FISMA	Federal Information Security Modernization Act
GRC	Governance Risk and Compliance
HECVAT	Higher Education Community Vendor Assessment Toolkit
HIPAA	Health Insurance Portability and Accountability Act
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
IaaS	Infrastructure as a Service
IaC	Infrastructure as Code
IAM	Identity and Access Management
IDS	Intrusion Detection System
IG	Implementation Group
IOCs	Indicators of Compromise
IoT	Internet of Things
IP	Internet Protocol
IPS	Intrusion Prevention System
ISAC	Information Sharing and Analysis Center
ISO	International Organization for Standardization

IT	Information Technology
LotL	Living off the Land
MDM	Mobile Device Management
MFA	Multi-Factor Authentication
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge®
MS-ISAC	Multi-State Information Sharing and Analysis Center
NaaS	Network as a Service
NCSA	National Cyber Security Alliance
NIDS	Network Intrusion Detection System
NIST	National Institute of Standards and Technology
OS	Operating System
OSS	Open Source Software
OVAL	Open Vulnerability and Assessment Language
OWASP	Open Web Application Security Project
PaaS	Platform as a Service
PAM	Privileged Access Management
PCI	Payment Card Industry
SaaS	Software as a Service
SAFECode	Software Assurance Forum for Excellence in Code
SCADA	Supervisory Control and Data Acquisition
SIEM	Security Information and Event Management
SIP	System Integrity Protection
SMS	Short Messaging Service
SOC	Security Operations Center
SOC 2	Service Organization Control 2
SPF	Sender Policy Framework

SQL	Structured Query Language
SSDF	Secure Software Development Framework
SSH	Secure Shell
SSO	Single Sign-On
Telnet	Teletype Network
TLS	Transport Layer Security
TTPs	Tactics, Techniques, and Procedures
U.K.	United Kingdom
URL	Uniform Resource Locator
USB	Universal Serial Bus
VPN	Virtual Private Network
WDEG	Windows Defender Exploit Guard
WPA2	Wi-Fi Protected Access 2
XCCDF	Extensible Configuration Checklist Description Format

Change Log

Two minor releases (v8.1.1 – August 2024 and v8.1.2 – March 2025) have resulted in the following changes:

- Correction of some minor typos in our [Asset Class section \(pg. 8\)](#) and [Glossary \(Appendix A3\)](#)
- Update of hyperlinks throughout the document, based on the recent release of the [CIS Controls Resources webpage](#)
- Correction of two Security Function typos – Safeguards 16.11 (Protect) and 16.13 (Detect)
- Correction of some minor typos for Safeguards 5.1, 8.9, 11.1, 16.11, and 17.5.

Glossary

Accounts

Accounts are a profile, identity, or membership created for a person, group, or machine entity that grant access to resources or functionalities within a computer system or network. A system of accounts is important for managing permissions and security levels across an enterprise, and an individual may have access to multiple accounts depending on job roles and security requirements. User accounts are for individual users and are tailored for the specific tasks their roles and responsibilities require. User accounts, administrator accounts, and service accounts are subsets of accounts.

Administrator accounts

Accounts for users requiring escalated privileges. The accounts are used for managing aspects of a computer, domain, or the whole enterprise information technology infrastructure. Each administrator account should be assigned to a single user. Common administrator account subtypes include root accounts, local administrator, domain administrator accounts, and network or security appliance administrator accounts.

Application Programming Interface (API)

A set of rules and interfaces for software components to interact with each other in a standardized way. APIs allow applications to access and communicate with both internal and external resources.¹

Applications

A program, or a group of programs, running on top of an operating system hosted on an enterprise asset. Example application types include web, database, cloud-based, and mobile. Applications are considered a software asset in this document.

Asset Class

A group of information assets that are evaluated as one set based on their similarity. Devices, Software, Data, Users, Network, and Documentation are examples.

Authentication systems

A system or mechanism used to identify a user through associating an incoming request with a set of identifying credentials. The credentials provided are compared to those on a file in a database of the authorized user's information on a local operating system, user directory service, or within an authentication server. Examples of authentication systems can include active directory, Multi-Factor Authentication (MFA), biometrics, and tokens.

Authorization systems

A system or mechanism used to determine access levels or user/client privileges related to system resources including files, services, computer programs, data, and application features. An authorization system grants or denies access to a resource based on the user's identity. Examples of authorization systems can include active directory, access control lists, and role-based access control lists.

Bi-annually

Every six months. Any tasks that should be done bi-annually should also be repeated whenever significant change has occurred that would affect the network or devices in question, including changes such as hardware upgrades or mergers and acquisitions.

Breach

The loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where: a person other than an authorized user accesses or potentially accesses sensitive or confidential information; or an authorized user accesses sensitive or confidential information for other than authorized purposes.

Cloud environment

A virtualized environment that provides convenient, on-demand network access to a shared pool of configurable resources such as network, computing, storage, applications, and services. There are five essential characteristics to a cloud environment: on-demand self-service, broad network access, resource pooling, rapid elasticity, and measured service. Some services offered through cloud environments include Software as a Service (SaaS), Platform as a Service (PaaS), and Infrastructure as a Service (IaaS).

¹ NIST: https://csrc.nist.gov/glossary/term/application_programming_interface